

Report Estrarre un Eseguibile da un PCAP

Obiettivo dell'Analisi

L'obiettivo di questa sessione è stato analizzare un file di cattura del traffico di rete (nimda.download.pcap) per individuare il download di un malware noto "Nimda" ed estrarre l'eseguibile malevolo direttamente dai pacchetti di rete per una successiva analisi.

Procedura Operativa e Risultati

Preparazione e Identificazione del File

Abbiamo navigato nella directory contenente i file di supporto (lab.support.files/pcaps) e verificato la presenza del file target nimda.download.pcap.

Wireshark è stato lanciato da riga di comando per aprire il file di cattura.

Analisi del Traffico HTTP

Esaminando i primi pacchetti, abbiamo identificato il Three-way handshake TCP (SYN, SYN-ACK, ACK) tra l'host sorgente 209.165.200.235 e la destinazione 209.165.202.133.

Evento Chiave: Il pacchetto numero 4 mostra una richiesta HTTP GET per il file /W32.Nimda.Amm.exe. Questo conferma che un utente o un sistema ha tentato di scaricare esplicitamente questo eseguibile.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	209.165.200.235	209.165.202.133	TCP	74	48598 → 6666 [SYN] Seq=0 Win=29200
2	0.000259	209.165.202.133	209.165.200.235	TCP	74	6666 → 48598 [SYN, ACK] Seq=0 Ack=
3	0.000297	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=1 Ack=1 Win
4	0.000565	209.165.200.235	209.165.202.133	HTTP	230	GET /W32.Nimda.Amm.exe HTTP/1.1
5	0.000588	209.165.202.133	209.165.200.235	TCP	66	6666 → 48598 [ACK] Seq=1 Ack=165 W
6	0.000708	209.165.202.133	209.165.200.235	TCP	324	6666 → 48598 [PSH, ACK] Seq=1 Ack=
7	0.000827	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=165 Ack=255

Ricostruzione del Flusso TCP

Tecnica: Utilizzando la funzione "Follow TCP Stream", abbiamo ricostruito l'intera conversazione tra client e server.

Osservazioni:

```
HTTP/1.1 200 OK
Server: nginx/1.12.0
Date: Tue, 02 May 2017 14:26:50 GMT
Content-Type: application/octet-stream
Content-Length: 345088
Last-Modified: Fri, 14 Apr 2017 19:17:25 GMT
Connection: keep-alive
ETag: "58f12045-54400"
Accept-Ranges: bytes
```

```
MZ.....@.....
!..L.!This program cannot be run in DOS mode.
```

Il corpo della risposta contiene dati binari che iniziano con i caratteri MZ e la stringa This program cannot be run in DOS mode. Questa è la firma inconfondibile dell'header di un file eseguibile Windows.

```
$.....M|... ..eN.....e_.....eY.....eI...
...eC.....e^.....e[.....Rich.....PE..d.....L..
.....".....r.....J.....
.....@.....X..d.....X.....&...
.....$.p..8.....H...
.....text...p.....r.....rdata...I.....J..v...
.....@..@.data.....@..pdata...&.....(.....
.....@..@.rsrc..X.....@..@.reloc..$.B.....
.....@..B7..L@.....LK.....LU.....LK.....Lb.....L.....msvcrt
.dll.NTDLL.DLL.KERNEL32.dll.api-ms-win-core-processthreads-l1-1-0.DLL.WINBRAND.dl
l.....
.....H;
.....$Q..H...f.....Q.....%.H..teSH..H.....H..
tO.....L.A.H...t>H.L$0I;.....H;H.C.....H.....7...L..3.H...1...
.....H..[.....%:.....H.\$.H.t$.WH.....H...H...%...=...
.....$...-...$...=.....t$D.F_H.L$ 3.....H.T$ E3.H...P1...uf;.....;.....
...;3.....;.....<.....Hc.H.
.b..H...H...H.....H..}...H..t
H9X...Z...=*...t.H..t.H.T$ A..H...0.....L..$.I..[.I.s I.._.....H..(.....
.....H...j.....H.....H...G...t..y.....<...!...3.....H.
.a...H.....t1.
N.....<.....H..a...H..t H.
.....H..(.....H..(H.....H.....3...H..(.....>.;.....H.Fp.....F...;.....
.H.Fp.....*...D.X.3.H...H..~pf..H..H..H.....C..H...Y.....H..$P...H3.....L..$`...
I..[(I.s0I.{8I..A_A)A\.....H..H..[...5...i...H.A..F.....H.\$.WH.. 3.L...m...H
;t.H...3.H..f..H..H..H..H#..I.....6...L.....H..3...+...;.....H...
...H.\$0H.._.....%:|.....H.\$.H.l$.H.t$.WH.. ..3.H..H..H;..tiH..f9(t..
```

1 client pkt, 243 server pkts, 1 turn.

Entire conversation (345 kB) Show as ASCII No delta times Stream 0

I caratteri incomprensibili visualizzati nel flusso sono la rappresentazione ASCII del codice binario del programma. Le parole leggibili sparse sono le stringhe di testo contenute nel programma (variabili, nomi di funzioni, ecc.).

Risposta alla Domanda Sfida: Analizzando i frammenti di parole nel codice ASCII possiamo riconoscere alcune stringhe familiari:

"Windows Command Processor" "cmd.exe" "Microsoft Corporation"

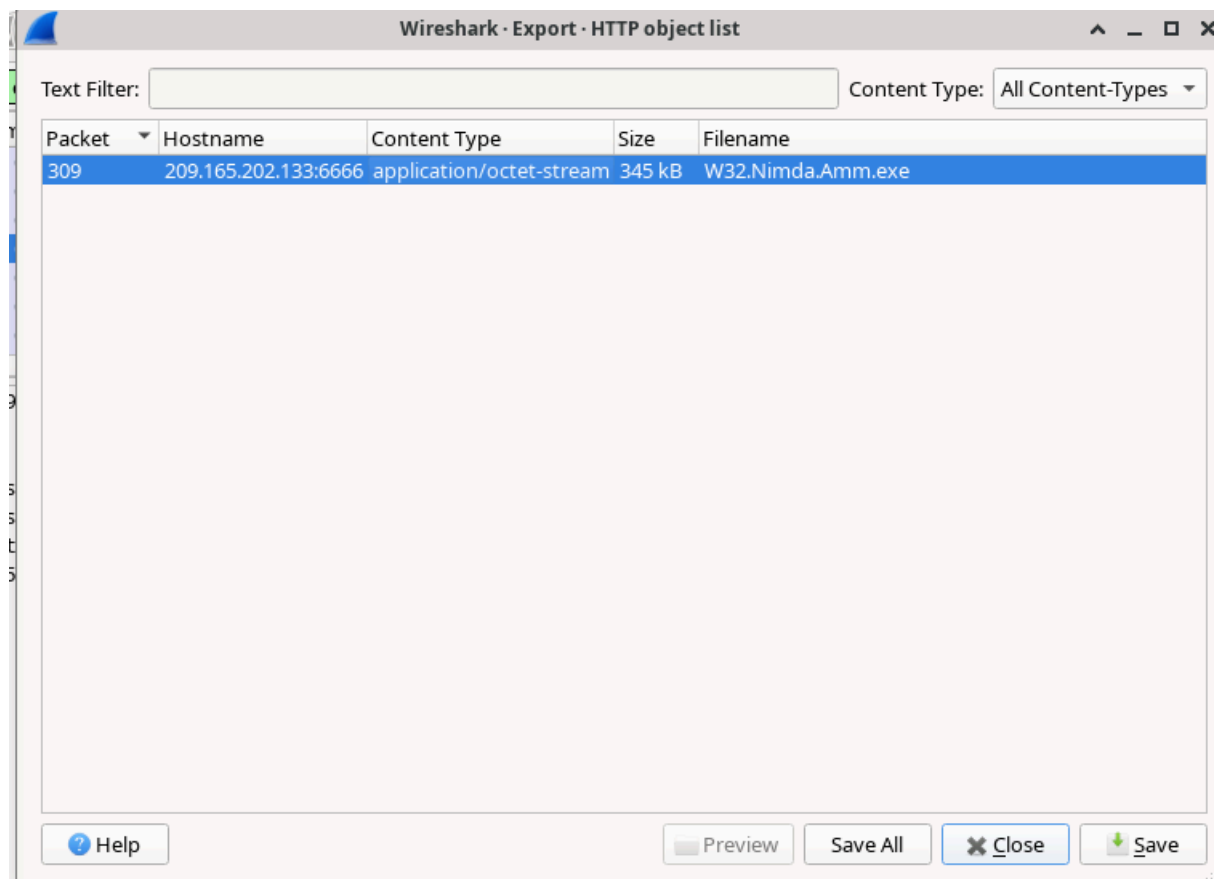
Comandi interni come: DIR, COPY, DEL, FOR, IF, GOTO, CALL.

Manifest XML che conferma si tratta di "Microsoft.Windows.FileSystem.CMD"

Quindi possiamo dedurre dalle sole parole nel TCP Stream che il file scaricato non è l'omonimo Worm W32.Nimda.Amm.exe ma un semplice file cmd.exe di windows

Estrazione dell'Artefatto

Per effettuare il download del malware, abbiamo utilizzato la funzione File > Export Objects > HTTP di Wireshark.



È stato individuato un unico oggetto trasferito: W32.Nimda.Amm.exe (dimensione 345 kB).

Non ci sono stati altri oggetti trasferiti tramite HTTP.

Il file è stato salvato nella directory di analisi /home/analyst.

```
File Edit View Terminal Tabs Help
[analyst@secOps ~]$ ls -l
total 380
-rw-r--r-- 1 root    root      5424 Dec  2 09:03 capture.pcap
drwxr-xr-x 2 analyst analyst  4096 Dec  9 09:59 Desktop
drwxr-xr-x 3 analyst analyst  4096 Jun 18 20:17 Downloads
drwxr-xr-x 9 analyst analyst  4096 Jun 18 20:17 lab.support.files
drwxr-xr-x 3 analyst analyst  4096 Jun 18 19:55 scripts
drwxr-xr-x 2 analyst analyst  4096 Mar 21 2018 second_drive
-rw-r--r-- 1 analyst analyst   255 Dec  4 07:40 space.txt
-rw-r--r-- 1 analyst analyst   298 Dec  4 07:54 space.txt.save
-rw-r--r-- 1 analyst analyst 345088 Dec  9 09:57 W32.Nimda.Amm.exe
drwxr-xr-x 5 analyst analyst  4096 Jun 18 19:27 yay
[analyst@secOps ~]$
```

Tramite il comando **ls -l** abbiamo confermato che il file è stato salvato correttamente con la dimensione attesa.

```
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable for MS Windows 6.01 (console), x86-64, 6 sections
[analyst@secOps ~]$
```

Il comando `file W32.Nimda.Amm.exe` ha confermato la natura del file: PE32+ executable, for MS Windows. Questo prova definitivamente che abbiamo estratto un programma eseguibile per Windows dal traffico di rete.

Conclusioni e Prossimi Passi

L'esercizio ha dimostrato con successo come intercettare ed estrarre un payload malevolo dal traffico di rete non cifrato.

Il prossimo passo consigliato per un Analista dopo che l'eseguibile è stato estratto, sarebbe calcolare l'hash del file e verificarlo su database di threat intelligence come VirusTotal, per ottenere dettagli sul suo comportamento specifico. Se risultasse malevolo si potrebbe testare in un ambiente controllato per comprendere meglio il suo comportamento.